

Ayan Ambesh

+91 9311364109 | ambesh.infosec@gmail.com | github.com/AYAN-AMBESH | whokilledtulpa.com |
linkedin.com/in/ayan-ambesh

SUMMARY

Offensive security professional specializing in Vulnerability Assessment and Penetration Testing (VAPT) across web applications, mobile applications, and Active Directory environments. Experienced in static and dynamic application security testing (SAST/DAST), privilege escalation, and OSINT-driven reconnaissance, with practical depth built through 100+ mobile application security assessments and extensive HackTheBox/CTF exploitation. Builder of open-source security tooling, including custom SAST scanners and an authorization-enforced intercepting proxy.

SKILLS

Security: Web Application Pentesting, Mobile Application Pentesting, Network Penetration Testing, Active Directory Exploitation, SAST & DAST, Privilege Escalation, OWASP Top 10, OSINT

Tools: Burp Suite, Nmap, Metasploit, BloodHound, Mimikatz, Impacket Suite, Frida, Wireshark, Nessus, YARA, Cellebrite UFED

Programming: Python, Bash, Rust

Platforms: Linux, Windows, Active Directory, Docker, Git

EXPERIENCE

Privado.ai, Remote

Security Researcher (Privacy)

June 2023 – August 2023

- Conducted static application security testing (SAST) and code review of 100+ Android applications to identify privacy leaks, hardcoded keys, and security vulnerabilities.
- Performed dynamic application security testing (DAST) using Frida and Burp Suite to intercept API traffic, bypass SSL pinning, and triage mobile application threats.
- Built custom Python automation scripts to parse network logs and intercept flows, accelerating security vulnerability triage.
- Presented vulnerability findings and mitigation strategies directly to stakeholders to guide remediation efforts.

Forensic Science Laboratory, Rohini, Delhi

Digital Forensics Intern

May 2026 – June 2026

- Extracted and analyzed digital evidence from mobile and DVR systems using Cellebrite UFED/Premium and Tableau under forensic expert supervision.
- Assisted with Crime Branch, CBI, and ACB cases by analyzing digital media while maintaining a strict chain-of-custody lifecycle.
- Documented detailed case findings, evidence logs, and forensic examination reports.

PROJECTS

Splice – Authorization-Enforced Intercepting Proxy

github.com/AYAN-AMBESH/splice

- Built a MITM HTTP/HTTPS intercepting proxy that enforces engagement scope as a hard control, evaluating every request against OPA/Rego policy and returning 403 Forbidden for out-of-scope hosts with full decision logging for compliance artifacts.
- Modeled endpoints and parameters as a graph database to trace attack chains from unauthenticated entry points to sensitive data sinks, moving beyond flat site-map trees.
- Designed a sandboxed, hot-loadable Lua plugin architecture for custom security checks and compiled to a single signed, dependency-free binary that chains inline with Burp and ZAP.

SaPyScan – Python Static Application Security Testing Tool

github.com/AYAN-AMBESH/sapyscan

- Built an AST-based SAST scanner in Python that performs taint tracking through assignments, imports, and method calls to detect injection sinks, with sanitizer-aware analysis to reduce false positives.
- Implemented detection rules covering OWASP Top 10 risk classes – SQL/command injection, XSS, insecure deserialization, SSRF, path traversal, hardcoded secrets, weak crypto, and SSL misconfiguration.
- Added multiprocessing support for large-codebase scanning, SARIF output for CI/CD pipeline integration, inline suppression syntax, and an automated SQL-injection autofix mode.
- Generated interactive HTML dashboards with severity-ranked findings, code snippets, and remediation guidance to streamline triage for security reviewers.

JavScan – Java Static Application Security Testing Tool

github.com/AYAN-AMBESH/javscan

- Built a Rust SAST engine using tree-sitter to parse Java into a real AST, performing intraprocedural taint analysis that tracks user-controlled data from sources through assignments to dangerous sinks.
- Implemented 28 security rules mapped to CWE and OWASP Top 10 – SQL/command injection, XSS, insecure deserialization, path traversal, and weak cryptography – scanning roughly 60,000 lines of Java per second via parallel processing.
- Added SARIF 2.1.0 output for GitHub Code Scanning, baseline diffing to fail CI only on newly introduced findings, inline suppression syntax, and an interactive HTML dashboard.

COMMUNITY TALK

DEF CON Groups VR (DCGVR) Talk – Java & Smali: Bridging the Gap

youtu.be/NyuJ_lK6QsU | Aug 2024

Delivered a technical talk on structural and syntactic mapping between Java and Smali for Android reverse engineering.

PUBLICATIONS

Refined Human-Computer Interaction: Enhancing Efficiency and Collaboration

link.springer.com/chapter/10.1007/978-981-97-0892-5_46

Springer | DOI:10.1007/978-981-97-0892-5_46

EDUCATION

National Forensic Sciences University (NFSU), Delhi

MSc in Digital Forensics & Information Security 2025 – 2027 (Ongoing)

Guru Gobind Singh Indraprastha University (GGSIPU), Delhi

Bachelor of Computer Applications (BCA) 2020 – 2023

St. Xavier Sr. Sec. School

Senior Secondary 2020